

Security+ 2.1 · Threat Actors

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.1 — Threat Actors (10:23)** · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: Threat actors are defined by their motivation and resources: nation-state (government-backed, espionage/sabotage, APT), organized crime (profit-driven, ransomware, credential theft), hacktivist (ideological, e.g., Anonymous), insider (internal threat, intentional or negligent), script kiddie (uses ready-made exploits, high volume, low sophistication), shadow IT (unofficial apps creating entry points), and competitors (industrial espionage).

High-Yield Core Concepts Tested on Exam

- APT (Advanced Persistent Threat): nation-state, long-term, highly resourced
- Organized crime = financial gain; hacktivist = ideology; nation-state = political/military
- Script kiddie: uses existing exploits, low sophistication, high volume
- Insider threat: already inside the trust boundary, often the highest risk
- Shadow IT: unauthorized applications that bypass security controls

Exam Tips & Classic Scenarios

- 'motivated by political/social ideology' = hacktivist
- 'long-term, nation-state, persistent' = APT
- 'uses ready-made tools and exploits' = script kiddie
- 'employee accidentally leaks data' = insider threat (negligent)

Typical Exam Scenario: Scenario: 'A government-funded group spies on critical infrastructure for months' = APT (nation-state) — not hacktivist or criminal.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.1 — Threat Actors)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. A scammer sends an email IMPERSONATING the CEO and orders the finance department to make an urgent transfer. What attack is this?

- A)** BEC / CEO fraud
- B)** Whaling
- C)** Vishing
- D)** Tailgating

2. In the 'initial access' of modern ransomware, what is the MOST exploited flaw?

- A)** Misconfigured firewall
- B)** Phishing + VPN without MFA / leaked credential
- C)** Exposed network cable
- D)** Lack of antivirus

3. The NIST CSF framework organizes security into 5 functions. What are they?

- A)** Install, Update, Test, Audit, Archive
- B)** Identify, Protect, Detect, Respond, Recover
- C)** Plan, Do, Check, Act, Review
- D)** Prevent, Punish, Predict, Prove, Publish

4. Corporate scenario (Threat Actors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.1), an analyst evaluates the following technical requirement: 'APT (Advanced Persistent Threat): government-backed — enormous resources, long-term target'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: APT (Advanced Persistent Threat): government-backed — enormous resources, long-term target.

5. Corporate scenario (Threat Actors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.1), an analyst evaluates the following technical requirement: 'Organized crime = money; hacktivist = ideology; nation-state = political/military'. What is the best applicable recommendation or control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Organized crime = money; hacktivist = ideology; nation-state = political...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Threat Actors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.1), an analyst evaluates the following technical requirement: 'Script kiddie: uses ready-made exploits — volume, low sophistication'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Script kiddie: uses ready-made exploits — volume, low sophistication...
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Threat Actors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.1), an analyst evaluates the following technical requirement: 'Insider: the greatest risk because they are already INSIDE the trust boundary.' What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Insider: the greatest risk because they are already INSIDE the trust boundary...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Threat Actors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.1), an analyst evaluates the following technical requirement: "'motivated by political/social ideology' = hacktivist'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'motivated by political/social ideology' = hacktivist...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Threat Actors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.1), an analyst evaluates the following technical requirement: 'long-term, nation-state, persistent' = APT. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: 'long-term, nation-state, persistent' = APT

10. Corporate scenario (Threat Actors): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.1), an analyst evaluates the following technical requirement: 'Typical scenario: "a government-funded group spies on critical infrastructure for months" = APT (nation-state) — not hacktivist or criminal.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators with generic credentials
- D)** Implement the corresponding solution: Typical scenario: 'a government-funded group spies on critical infrastructure for...

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — BEC / CEO fraud.

✓ **Why it is correct:** The correct answer is 'BEC / CEO fraud'. Business Email Compromise (BEC) is a category of social engineering attack where the attacker impersonates a high-level executive (such as the CEO) or a trusted business partner to induce employees to make unauthorized financial transfers or disclose confidential information. In the described scenario, the scammer sends a fraudulent email impersonating the CEO and orders an urgent transfer to the finance department. This perfectly fits the definition of BEC, which CompTIA recognizes as an attack vector based on impersonation and social engineering. The specific variant where the CEO is impersonated is called CEO fraud. Therefore, the option 'BEC / CEO fraud' best describes the attack.

✗ Why the others are wrong:

- *Whaling:* Whaling is a type of phishing attack specifically targeting high-level executives (such as CEOs, CFOs, etc.). The goal is to obtain confidential information or access to critical systems through fraudulent emails impersonating trusted sources. However, in the described scenario, the attacker is not targeting the CEO but impersonating them to deceive the finance department. Therefore, whaling is not the correct term, as it describes the target (the executive) and not the modus operandi of impersonating the CEO to defraud subordinates.
- *Vishing:* Vishing is the practice of social engineering conducted via phone calls (voice phishing), where the attacker impersonates a trusted entity to obtain sensitive information, such as passwords or financial data. In the scenario, the attack occurs via email, not phone. Therefore, vishing does not apply to the channel used. Additionally, vishing does not necessarily involve impersonating the CEO to order transfers, but rather fraudulent calls in general.
- *Tailgating:* Tailgating is a physical unauthorized access technique where a person follows another into a restricted area without authenticating, usually exploiting the courtesy or distraction of an authorized employee. It is unrelated to email social engineering attacks or financial fraud. The scenario describes a cyber attack based on fraudulent email, not a physical intrusion. Therefore, tailgating is completely inadequate for the situation.

2) B — Phishing + VPN without MFA / leaked credential.

✓ **Why it's correct:** The correct answer is: Phishing + VPN without MFA / leaked credential. In the Threats, Vulnerabilities, and Mitigations domain of CompTIA Security+ SY0-701, modern ransomware (such as Ransomware-as-a-Service operations) uses initial access tactics that exploit the human factor and inadequate authentication configurations. Phishing remains the most prevalent vector: malicious emails, social media messages, or fake websites trick users into handing over credentials or executing malicious payloads. Additionally, VPNs without MFA (multi-factor authentication) allow credentials leaked in data breaches or purchased on underground markets to be used directly for remote access to the corporate network. The combination of phishing to obtain credentials and the absence of MFA on VPNs is one of the most exploited flaws, as it bypasses traditional perimeters and gives the attacker legitimate access to the network. CompTIA emphasizes that implementing MFA is a critical mitigation against this vector.

✗ Why the others are wrong:

- *Misconfigured firewall:* A misconfigured firewall can allow unauthorized traffic, but it is not the most exploited initial access vector in modern ransomware. Traditional firewalls operate at the network layer and, when properly configured, block exposed ports and services. However, modern attacks often use valid credentials obtained through phishing or leaks, making traffic appear legitimate and not blocked by firewall rules. Furthermore, firewall exploitation typically requires

specific vulnerabilities or severe misconfigurations, which are less common than credential compromise. Therefore, it is not the most exploited flaw.

- *Exposed network cable*: An exposed network cable is a physical vulnerability that allows an attacker with local access to connect to the network. Although it is a risk in environments with poor physical access control, it is not a typical initial access vector for modern ransomware, which is generally executed remotely through phishing, exploitation of exposed services, or compromised credentials. Physical attacks require proximity and can be mitigated with physical security, but they do not represent the main entry point for large-scale ransomware campaigns.
- *Lack of antivirus*: The absence of antivirus is a control deficiency, but it is not the most exploited initial access vector. Modern antivirus solutions are effective against known malware, but sophisticated ransomware often uses evasion techniques (obfuscation, fileless, living-off-the-land) that can bypass signature-based solutions. Moreover, initial access occurs before ransomware execution, through compromised credentials or phishing. The lack of antivirus worsens the impact, but it is not the primary flaw that allows the attacker's entry. CompTIA highlights that awareness and MFA are more critical to prevent initial access.

3) B — Identify, Protect, Detect, Respond, Recover.

✓ **Why it's correct:** The NIST Cybersecurity Framework (CSF) 2.0 organizes cybersecurity activities into five core functions: Identify, Protect, Detect, Respond, and Recover. These functions represent the complete lifecycle of cyber risk management. 'Identify' involves understanding the organizational context, assets, risks, and vulnerabilities. 'Protect' covers implementing safeguards to ensure delivery of critical services. 'Detect' defines activities to identify the occurrence of cybersecurity events. 'Respond' comprises actions taken after an incident is detected. 'Recover' focuses on restoring capabilities or services that were impaired. This framework is widely adopted and required in the Security Architecture and Design domain of the CompTIA Security+ (SY0-701) certification, specifically in objective 2.1, which deals with frameworks and guidelines.

✗ **Why the others are wrong:**

- *Install, Update, Test, Audit, Archive*: These terms describe generic steps of an IT operational process, such as a software lifecycle or patch management, but they do not constitute the NIST CSF functions. 'Install' and 'Update' refer to system deployment and maintenance; 'Test' is a verification activity; 'Audit' is a compliance assessment; and 'Archive' is a data retention practice. None of these actions correspond to the high-level strategic functions defined by the NIST CSF, which are risk-oriented rather than tactical tasks.
- *Plan, Do, Check, Act, Review*: This is a variation of the PDCA cycle (Plan-Do-Check-Act), used in quality management and continuous improvement systems, such as ISO 9001. Although the NIST CSF can be integrated into continuous improvement processes, its five functions are not 'Plan, Do, Check, Act, Review'. PDCA is a generic management model, while CSF functions are specific to cybersecurity and have their own scope and definitions. The inclusion of 'Review' as a fifth step is a distortion, as the classic PDCA has four steps.
- *Prevent, Punish, Predict, Prove, Publish*: These terms are not part of any recognized cybersecurity framework. 'Prevent' is a goal, but not a CSF function; 'Punish' is a disciplinary or legal action, not a security function; 'Predict' is an aspirational goal, not an operational function; 'Prove' and 'Publish' are audit and communication actions, respectively, but they do not compose the NIST CSF structure. This alternative mixes concepts of justice, prediction, and disclosure, with no relation to the official functions of the framework.

4) D — Implement the corresponding solution: APT (Advanced Persistent Threat): government-backed — enormous resources, long-term target..

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.1 (Threat Actors): APT (Advanced Persistent Threat): government-backed — enormous

resources, long-term target. APTs are highly sophisticated, well-funded actors (often nation-state or state-sponsored) that maintain stealthy persistence over extended periods to achieve strategic objectives.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

5) B — Implement the corresponding solution: Organized crime = money; hacktivist = ideology; nation-state = political....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.1 (Threat Actors): Organized crime = money; hacktivist = ideology; nation-state = political/military. This classification reflects the primary motivations of different threat actor types, which is a key exam concept.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) C — Implement the corresponding solution: Script kiddie: uses ready-made exploits — volume, low sophistication....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.1 (Threat Actors): Script kiddie: uses ready-made exploits — volume, low sophistication. A script kiddie is an unskilled attacker who uses existing tools, scripts, and exploits developed by others to launch attacks. They typically lack deep technical knowledge and rely on volume and easily available attack kits. While their attacks may be less sophisticated, they can still cause significant damage. Defenses include timely patching, strong endpoint protection, and network segmentation.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Insider: the greatest risk because they are already INSIDE the trust boundary....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.1 (Threat Actors): Insider: the greatest risk because they are already INSIDE the trust boundary. Insiders already possess authorized access, knowledge of internal systems, and implicit trust, which makes detection and prevention harder. Mitigations include least privilege, separation of duties, user behavior analytics, and strict offboarding.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to incident detection and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

8) A — Implement the corresponding solution: 'motivated by political/social ideology' = hacktivist....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.1 (Threat Actors): 'motivated by political/social ideology' = hacktivist.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

9) D — Implement the corresponding solution: 'long-term, nation-state, persistent' = APT.

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.1 (Threat Actors): 'long-term, nation-state, persistent' = APT. Advanced Persistent Threats are well-resourced, state-sponsored actors conducting prolonged campaigns.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

10) D — Implement the corresponding solution: Typical scenario: 'a government-funded group spies on critical infrastructure for....'

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.1 (Threat Actors): Typical scenario: 'a government-funded group spies on critical infrastructure for months' = APT (nation-state) — not hacktivist or criminal.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.